studeersnel

Báo cáo bài tập lớn môn học ATBM HTTT

An toàn và Bảo mật Hệ thống thông tin (Học viện Công nghệ Bưu chính Viễn thông)

Scan to open on Studeersnel

Studocu is not sponsored or endorsed by any college or university
Downloaded by T? Thiên (thien24112005@gmail.com)

BỘ THÔNG TIN TRUYỀN THÔNG
HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG

BÀI TẬP LỚN

Đề tài: Tìm hiểu về hệ thống phát hiện tấn công, xâm nhập OSSEC

Môn học: An toàn bảo mật hệ thống thông tin
Nhóm học phần: 03
Nhóm BTL: 11

Nguyễn Vinh Hiển	**B21DCCN047**
Vũ Thành Luân	**B21DCCN502**
Lê Quý Toàn	**B21DCCN117**
Trần Việt Hoàng	**B21DCCN057**
Lê Văn Trung	**B21DCCN731**

Hà Nội – 2024

Downloaded by T? Thiên (thien24112005@gmail.com)

Lời cảm ơn

Lời đầu tiên, nhóm em xin được gửi lời cảm ơn chân thành nhất đến thầy Đinh Trường Duy. Trong quá trình học tập và tìm hiểu môn **An toàn bảo mật hệ thống thông tin** em đã nhận được rất nhiều sự quan tâm, giúp đỡ, hưỡng dẫn tâm huyết và tận tình của thầy. Thầy đã giúp em tích lũy thêm nhiều kiến thức về môn học này để có thể hoàn thành được bài tiểu luận về đề tài: Tìm hiểu về hệ thống phát hiện tấn công, xâm nhập OSSEC.

Trong quá trình làm bài chắc chắn khó tránh khỏi những thiếu sót. Do đó, em kính mong nhận được những lời góp ý của thầy để bài tiểu luận của em ngày càng hoàn thiện hơn.

Em xin chân thành cảm ơn!

Downloaded by T? Thiên (thien24112005@gmail.com)

Mục lục

1. Giới thiệu *4*

2. Nội dung *4*

2.1 Kiến trúc **4**

2.2 Cài đặt **6**

2.3 Cấu hình **10**

2.4 Tạo luật **11**

2.5 Xây dựng 3 kịch bản phát hiện tấn công **15**

3. Kết luận *22*

Downloaded by T? Thiên (thien24112005@gmail.com)

1. Giới thiệu

Trong bối cảnh ngày nay, việc bảo vệ hệ thống thông tin trở nên ngày càng quan trọng đối với các tổ chức và doanh nghiệp. Với sự phát triển của công nghệ thông tin, mối đe dọa từ các tấn công mạng và xâm nhập hệ thống đã trở nên phức tạp và đa dạng hơn bao giờ hết. Để đối phó với những mối đe dọa này, các hệ thống phát hiện tấn công và xâm nhập (IDS/IPS) đã trở thành một phần không thể thiếu của cơ sở hạ tầng an ninh mạng.

Trong khuôn khổ của nghiên cứu này, chúng tôi tập trung vào một trong những hệ thống phát hiện tấn công và xâm nhập phổ biến và mạnh mẽ - OSSEC. OSSEC là một dự án mã nguồn mở được phát triển bởi Daniel Cid từ năm 2004, với mục tiêu cung cấp một giải pháp an ninh mạng toàn diện cho các tổ chức và doanh nghiệp. Hệ thống này không chỉ giúp phát hiện các tấn công mạng, mà còn cung cấp các công cụ và cơ chế để ngăn chặn và đáp ứng đối với chúng.

Bài tiểu luận này sẽ đi sâu vào tìm hiểu về kiến trúc, cài đặt, cấu hình và quy trình tạo luật của OSSEC. Chúng tôi sẽ trình bày một cái nhìn tổng quan về cách OSSEC hoạt động, cách triển khai và cấu hình nó để phù hợp với môi trường mạng cụ thể của một tổ chức, cũng như cách tạo ra các luật để phát hiện và báo cáo các hoạt động đáng ngờ trên hệ thống.Bằng cách nắm vững kiến thức về hệ thống phát hiện tấn công và xâm nhập OSSEC, chúng ta sẽ có cái nhìn rõ ràng và chi tiết hơn về cách bảo vệ hệ thống thông tin của chúng ta khỏi các mối đe dọa mạng ngày càng phức tạp.

2. Nội dung

2.1 Kiến trúc

2.1.1 Tổng quan về hệ thống phát hiện xâm nhập IDS

- IDS là hệ thống phát hiện các dấu hiệu của tấn công xâm nhập, đồng thời có thể khởi tạo các hành động trên các thiết bị khác để ngăn chặn tấn công. Khác với tường lửa, IDS không thực hiện thao tác ngăn chặn mà chỉ theo dõi các hoạt động trên mạng. IDS sẽ đánh giá sự xâm nhập đáng ngờ khi nó đã diễn ra đồng thời phát ra cảnh báo, nó theo dõi được các cuộc tấn công từ bên trong hệ thống.

- Phân loại:

  - *Network – based IDS(NIDS)* : IDS giám sát toàn bộ mạng ,nguồn thông tin là các gói dữ liệu đang lưu thông trên mạng ,được lắp đặt trước hoặc sau tường lửa.
  - *Host – based IDS(HIDS)* :IDS giám sát hoạt động của từng máy riêng biệt, nguồn thông tin chủ yếu của HIDS ngoài dữ liệu đến và đi từ máy chủ còn có hệ thống kiểm tra nhật kí hệ thống và kiểm tra hệ thống.
  - *Signature-based IDS*: IDS phát hiện xâm nhập dựa trên dấu hiệu của hành vi xâm nhập, thông qua phân tích lưu lượng mạng và log hệ thống.

Downloaded by T? Thiên (thien24112005@gmail.com)

- *Anomaly-based IDS*: IDS phát hiện xâm nhập bằng cách so sánh mang tính thống kê các hành vi hiện tại với hoạt động bình thường của hệ thống để phát hiện các bất thường (anomaly) có thể là dấu hiệu của xâm nhập.

2.1.2 Tổng quan về OSSEC

- OSSEC là hệ thống phát hiện xâm nhập dựa trên host (HIDS) dựa trên log mã nguồn mở, miễn phí, đa nền tảng có thể mở rộng và có nhiều cơ chế bảo mật khác nhau. OSSEC có thể phát hiện xâm nhập bằng cả chữ ký hoặc dấu hiệu bất thường. Các dấu hiệu bình thường và bất thường được mô tả trong bộ luật của OSSEC. OSSEC chỉ có thể cài đặt trên Windows với tư cách là một agent.
- Lý do OSSEC phát triển dựa trên HIDS:

- Phù hợp với môi trường dữ liệu mã hóa ngày càng phổ biến. HIDS có khả năng đọc được các dữ liệu (log) được mã hóa tại server nhận.
- Thích hợp trong các mạng được chuyển đổi nơi mà chỉ có máy chủ lưu trữ cuối cùng mới có thể nhìn thấy lưu lượng truy cập.
- Theo dõi được các tiến trình sử dụng của người dùng tại máy chủ.
- Có khả năng phát hiện và phản ứng với thời gian thực.
- HID có khả năng xác minh xem một cuộc tấn công hay xâm nhập trái phép có khả năng thành công hay thất bại.
- Khắc phục các cuộc tấn công như phân mảnh hay ghép nối phiên.

2.1.3 Các tính năng của OSSEC

- *Theo dõi và phân tích các log*: OSSEC thu nhập log theo thời gian thực từ nhiều nguồn khác nhau để phân tích và đưa ra cảnh báo. OSSEC phát hiện các cuộc tấn công trên mạng, hệ thống hoặc ứng dụng cụ thể bằng cách sử dụng log hàm nguồn thông tin chính. Log cũng rất hữu ích để phát hiện khai thác lỗ hổng phần mềm, vi phạm chính sách và các hoạt động không phù hợp khác.
- *Kiểm tra tính toàn vẹn của file*: Sử dụng hàm bằng mật mã có thể tính toán giá trị băm của mỗi file trong hệ điều hành dựa trên tên file, nội dung file và giá trị băm này là duy nhất. OSSEC có thể giám sát các ổ đĩa để phát hiện các thay đổi của giá trị băm này khi có ai đó hoặc điều gì đó, sửa đổi nội dung file hoặc thay thế phiên bản file này bằng phiên bản file khác
- *Kiểm tra Registry của Window*: Hệ thống Registry là danh sách thư mục tất cả các cài đặt phần cứng và phần mềm, các cầu hình hệ điều hành, người dùng, nhóm người dùng và các preference trên một hệ thống Microsoft Windows. Các thay đổi được thực hiện bởi người dùng và quản trị viên đối với hệ thống được ghi lại trong các khóa registry để các hoạt động thay đổi được lưu khi người dùng đăng xuất hoặc hệ thống được khởi động lại.
- *Phát hiện Rootkit*: OSSEC phát hiện rootkit dựa trên chữ ký rootkit là công cụ cho phép kẻ đột nhập khả năng xâm nhập vào máy tính bị cài rootkit và xóa dấu vết về sự tồn tại của nó. OSSEC có khả năng phát hiện root bằng cách đọc

Downloaded by T? Thiên (thien24112005@gmail.com)

file cơ sở dữ liệu về root và tiến hành quét hệ thống định kỳ, thực hiện các lời gọi hệ thống để phát hiện các file không bình thường, các tiến trình ẩn và so sánh chúng với cơ sở dữ liệu để phát hiện root

- *Phản ứng các cuộc tấn công chủ động*: Chúng cho phép các IDS nói chung và OSSEC nói riêng tự động thực thi các lệnh hoặc phản ứng khi một sự kiện hoặc tập hợp sự kiện cụ thể được kích hoạt. Phản ứng chủ động có thể được xác định bằng luật. Các lợi ích của phản ứng chủ động là rất lớn nhưng cũng rất nguy hiểm có thể ngăn chặn kết nối hợp pháp hoặc là lỗ hổng để kẻ tấn công khai thác.

2.1.4 Kiến trúc OSSEC

- OSSEC được thiết kế theo mô hình client – server, gồm 2 thành phần chính là OSSEC server và OSSEC agent.

OSSEC SERVER

- Đây là phần trung tâm và quan trọng nhất của OSSEC. Server là nơi lưu trữ dữ liệu. Tất cả các luật, bộ giải mã (decoder) cũng được lưu trữ trên server.
- Server còn đảm nhận nhiệm vụ quản lý các agent. Các agent kết nối với máy chủ trên cổng 1514 hoặc 514, giao thức UDP. Kết nối với cổng này phải được cho phép để các agent kết nối với manager
- Nhiệm vụ quan trọng nhất của server là phân tích các log nhận được từ các agent hay agentless (gọi chung là client) và xuất ra các cảnh báo. Các cảnh báo này có thể xuất ra cho các các công cụ xử lý log như Logstash, Elasticsearch để hiển thị cho người quản trị bằng Kibana, lưu trữ trong cơ sở dữ liệu.

OSSEC AGENT

- Agent (đầy đủ là installable agent) là một chương trình nhỏ, hoặc tập hợp các chương trình, được cài đặt trên các hệ thống được giám sát.
- Agent sẽ thu thập thông tin và gửi cho manager để phân tích và so sánh. Một số thông tin được thu thập trong thời gian thực, những thông tin khác theo định kỳ.
- Các module chức năng của agent là: giám sát host, kiểm tra tính toàn vẹn file trên máy host mà nó được cài, phát hiện rootkit trên máy host, đọc các log và gửi các log cho server.
- Agentless là tính năng hỗ trợ cho các thiết bị không cài đặt được agent theo cách bình thường như router, switch, tường lửa. Nó có chức năng như agent. Agentless kết nối để gửi thông điệp, log cho manager bằng các phương thức RPC

2.2 Cài đặt

B1: Cài đặt OSSEC server:

Downloaded by T? Thiên (thien24112005@gmail.com)

- OSSEC là hệ điều hành windows chỉ hỗ trợ cài đặt ossec agent, nó không hỗ trợ cài đặt ossec server. OSSEC server chỉ được hỗ trợ cài đặt trên các hệ điều hành hệ Linux/Unix.

- Cài đặt hệ điều hành Linux bằng phần mềm ảo hóa Vmware

- Tải gói cài đặt OSSEC tại: https://www.ossec.net/downloads.html

```
root@ubuntu:/home/ubuntu/Desktop# ls
ossec-hids-3.7.0  ossec-hids-3.7.0.tar.gz  ubiquity.desktop
root@ubuntu:/home/ubuntu/Desktop# cd ossec-hids-3.7.0
root@ubuntu:/home/ubuntu/Desktop/ossec-hids-3.7.0# ls
active-response  CHANGELOG.md  CONTRIBUTORS  Dockerfile  install.sh  src
BUGS             CONFIG        debian_files  etc         LICENSE     SUPPORT.md
build.sh         contrib       doc           INSTALL     README.md
root@ubuntu:/home/ubuntu/Desktop/ossec-hids-3.7.0#
```

- Sau đó chọn server để cài đặt

```
OSSEC HIDS v3.7.0 Installation Script - http://www.ossec.net

You are about to start the installation process of the OSSEC HIDS.
You must have a C compiler pre-installed in your system.

 - System: Linux luan-virtual-machine 6.5.0-26-generic
 - User: root
 - Host: luan-virtual-machine


 -- Press ENTER to continue or Ctrl-C to abort. --


1- What kind of installation do you want (server, agent, local, hybrid or help)?
 server
```

=> Cài đặt xong OSSEC server, toàn bộ dữ liệu cài đặt được lưu trong /var/ossec.

=> Sử dụng câu lệnh : /var/ossec/bin/ossec-control start để kiểm tra hoạt động của OSSEC

```
root@luan-virtual-machine:/var/ossec/bin# ./ossec-control start
Starting OSSEC HIDS v3.7.0...
Started ossec-execd...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-remoted...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
root@luan-virtual-machine:/var/ossec/bin#
```

*)LƯU Ý: Trước khi chuyển cài đặt agent trên client, cần đảm bảo rằng đã mở cổng 1514 hoặc 514

B2: Cài đặt OSSEC agent:

Downloaded by T? Thiên (thien24112005@gmail.com)

- Cài đặt agent trên hệ điều hành UNIX tương tự như cài đặt trên server, thay đổi server thành agent (tương tự khi cài đặt trên server cũng cần mở port UDP 1514,514)

- Cài đặt trên hệ điều hành Window bằng Vmware

- Tải gói cài đạt OSSEC tại : https://www.ossec.net/downloads.html

B3:Thêm Agent vào Server:

- Để OSSEC Server và OSSEC Agent có thể giao tiếp với nhau phía agent cần xác minh với OSSEC Server. Trafic giữa OSSEC Server và OSSEC Agent được mã hóa sử dụng khóa bí mật do phía server sinh ra sau đó import cho agent

- Chạy manage agent trên máy chủ OSSEC

```
Killing ossec-execd ..
OSSEC HIDS v3.7.0 Stopped
Starting OSSEC HIDS v3.7.0...
Started ossec-execd...
Started ossec-analysisd...
Started ossec-logcollector...
Started ossec-remoted...
Started ossec-syscheckd...
Started ossec-monitord...
Completed.
root@luan-virtual-machine:/var/www/html/ossec-wui# cd /var/ossec/bin/
root@luan-virtual-machine:/var/ossec/bin# ./manage_agents


****************************************
* OSSEC HIDS v3.7.0 Agent manager.     *
* The following options are available: *
****************************************
   (A)dd an agent (A).
   (E)xtract key for an agent (E).
   (L)ist already added agents (L).
   (R)emove an agent (R).
   (Q)uit.
Choose your action: A,E,L,R or Q:
```

- Thêm agent bao gồm:

+) Tên

```
Choose your action: A,E,L,R or Q: A

- Adding a new agent (use '\q' to return to the main menu).
  Please provide the following:
   * A name for the new agent:
```

+) Địa chỉ IP

+) Sau đó sẽ nhận được yêu cầu một địa chỉ IP duy nhất để gán cho máy khách

```
Agent information:
   ID:002
   Name:Tadat
   IP Address:002
```

+) Giải nén khóa cho agent

Downloaded by T? Thiên (thien24112005@gmail.com)

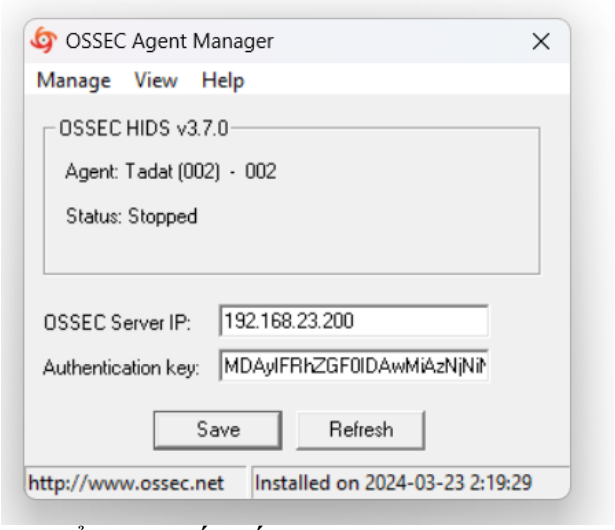
```
Available agents:
   ID: 001, Name: TaDat, IP: 001
   ID: 002, Name: Tadat, IP: 002
Provide the ID of the agent to extract the key (or '\q' to quit): 001

Agent key information for '001' is:
MDAxIFRhRGF0IDAwMSA5Nzg3YTkyMzE3Y2M5YjhjOGJkOTI5ZWU1Y2EyYjExNDhhYmFjOWFlMzI2YTY3
NGEwMTEzZDFhOTEyMTI2NDIx
```

+) Nhập địa chỉ IP

+) Sao chép key nhập vào máy OSSEC Agent

+) Khởi động lại quy trình OSSEC của manager. Khởi động agent

+) Chạy OSSEC với quyền Administrator



-Kiểm tra kết nối giữa Agent và Server:

+) Cài đặt Win trên máy Server

```
ossec-wui-0.9/site/user_mapping.php
root@luan-virtual-machine:/home/luan/Desktop# mv ossec-wui-0.9 /var/www/ossec-wu
i
root@luan-virtual-machine:/home/luan/Desktop# cd /var/www/ossec-wui/
root@luan-virtual-machine:/var/www/ossec-wui# ls
CONTRIB          img        lib            README         site
css              index.php  LICENSE        README.search
htaccess_def.txt js         ossec_conf.php setup.sh
root@luan-virtual-machine:/var/www/ossec-wui# ./set-up
bash: ./set-up: No such file or directory
root@luan-virtual-machine:/var/www/ossec-wui# ./setup.sh
trap: SIGHUP: bad trap
Setting up ossec ui...

Username: vuthanhluan
New password:
Re-type new password:
Adding password for user vuthanhluan
Enter your web server user name (e.g. apache, www, nobody, www-data, ...)

You must restart your web server after this setup is done.

Setup completed successfully.
root@luan-virtual-machine:/var/www/ossec-wui# ^C
```

+) Kiểm tra lại trên trang web: localhost/ossec-wui/

=>Xác nhận OSSEC Server đã khởi chạy

Downloaded by T? Thiên (thien24112005@gmail.com)

2.3 Cấu hình

- Cấu hình cho OSSEC chủ yếu được tổ chức trong ossec.conf, được viết bằng XML.
- Khi thiết lập lệnh từ xa trong cấu hình tác nhân được chia sẻ, phải bật lênh từ xa cho modun tác nhân , được kích hoạt bằng cách thêm ”/var/ossec/etc/local_internal_options.conf“ trong tác nhân: “wazuh command. remote commands=1”
- Các tác nhân có thể được định cấu hình từ xa bằng cách sử dụng tệp agent.conf .
- Các tác nhân có thể được nhóm lại với nhau để gửi cho họ một cấu hình tập trung duy nhất dành riêng cho nhóm. Mỗi tác nhân có thể thuộc nhiều hơn một nhóm và trừ khi được định cấu hình khác, tất cả các tác nhân đều thuộc một nhóm được gọi default.
- Người quản lý đẩy tất cả các tệp có trong thư mục nhóm đến các tác nhân thuộc nhóm này. Ví dụ: tất cả các tệp trong /var/ossec/etc/shared/default sẽ được đẩy đến tất cả các tác nhân thuộc default nhóm.
- Tệp ar.conf (trạng thái phản hồi hoạt động) sẽ luôn được gửi đến các tác nhân ngay cả khi nó không có trong thư mục nhóm.
- Tác nhân sẽ lưu trữ các tệp được chia sẻ /var/ossec/etc/shared, không phải trong một thư mục nhóm

)Agent.conf

- Chỉ agent.conf hợp lệ trên cài đặt máy chủ.
- Có agent.conf thể tồn tại trong mỗi thư mục nhóm tại /var/ossec/etc/shared.
-Ví dụ, đối với group 1 nhóm, nó đang ở trong /var/ossec/etc/shared/group1. Mỗi tệp này phải được wazuh người dùng đọc được.

)Quy trình cấu hình tập trung Agent.conf

- Cấu hình tập trung có thể được thực hiện bằng nhiều cách

C1: Định cấu hình agent.conf tệp: Chỉnh sửa tệp tương ứng với nhóm tác nhân. Ví dụ: đối với default nhóm, hãy chỉnh sửa tệp /var/ossec/etc/shared/default/agent.conf. Nếu tệp không tồn tại, hãy tạo nó

C2: Chạy /var/ossec/bin/verify-agent-conf: Mỗi lần bạn thực hiện thay đổi đối với agent.conf tệp, điều quan trọng là phải kiểm tra các lỗi cấu hình. Nếu bất kỳ lỗi nào được báo cáo bởi kiểm tra này, chúng phải được sửa trước khi thực hiện bước tiếp theo. Việc không thực hiện bước này có thể cho phép các lỗi được đẩy đến các tác nhân, điều này có thể ngăn các tác nhân chạy. Khi đó, rất có thể bạn sẽ buộc phải đến từng đại lý theo cách thủ công để khôi phục chúng.

C3: Đẩy cấu hình cho các tác nhân: Với mọi lưu giữ tác nhân (mặc định 10 giây), tác nhân sẽ gửi cho người quản lý tổng kiểm tra của tệp merge.md của nó và người quản lý sẽ so sánh nó với tệp hiện tại. Nếu tổng kiểm tra nhận được

Downloaded by T? Thiên (thien24112005@gmail.com)

khác với tổng kiểm tra có sẵn, trình quản lý Wazuh sẽ đẩy tệp mới đến tác nhân. Tác nhân sẽ bắt đầu sử dụng cấu hình mới sau khi được khởi động lại.

C4: Xác nhận rằng tác nhân đã nhận được cấu hình: Công agent_groupscụ hoặc điểm cuối API Wazuh GET / agent / {agent_id} / group / is_sync có thể cho biết liệu nhóm có được đồng bộ hóa trong tác nhân hay không?

C5: Khởi động lại đại lý: Theo mặc định, tác nhân sẽ tự động khởi động lại khi nhận được cấu hình được chia sẻ mới.Nếu auto_restart đã bị vô hiệu hóa (trong <client>phần Cấu hình cục bộ), tác nhân sẽ phải được khởi động lại theo cách thủ công để agent.conf tệp mới được sử dụng. Để sử dụng tính năng này, chúng ta cần đặt một tệp có tên files.yml dưới thư mục /var/ossec/etc/shared/. Khi trình quản lý khởi động, nó sẽ đọc và phân tích cú pháp tệp.

2.4 Tạo luật

2.4.1. Luật trong OSSEC

Luật (rules) là một phần vô cùng quan trọng trong hệ thống OSSEC, nó chính là cốt lõi trong việc đảm bảo hệ thống OSSEC có được hoạt động theo quy trình, chính xác và hiệu quả hay không. Rules có định dạng XML, được cấu hình trong ossec server /var/ossec/etc/ossec.config và nằm trong thẻ <ossec_config>. Rules được lưu trong /var/ossec/rules.

2.4.1.1. Đặc điểm

- Một vài thuộc tính của 1 rule trong OSSEC:

- Level (bắt buộc phải có): thể hiện mức độ của rule, ossec có 16 cấp độ từ 0-15.
- Id (bắt buộc phải có): id của rule, mỗi rule sẽ có một id riêng biệt không trùng lặp và là 1 trong các số từ 100-99999. (Khi tạo một luật mới nên đặt ip từ khoảng 100.000).
- Maxsize: chỉ định kích thước tối đa của sự kiện tiến hành, là 1 trong các số từ 1-99999.
- Frequency: chỉ định số lần rules được kiểm tra trước khi thực hiện.
- Timeframe: khung thời gian tính bằng giây, được sử dụng để kết hợp với frequency.
- Ignore: thời gian (s) bỏ qua rule này.
- Overwrite: Cho phép chỉnh sửa rule.

- Các cấp độ của luật:

- 00 - Ignored: Không thực hiện hành động nào. Khi gặp luật có cấp độ này thì sẽ không có thông báo. Các luật này được quét trước tất cả các luật khác. Chúng bao gồm các sự kiện không có sự liên quan về bảo mật.

- 01 - None (không).

Downloaded by T? Thiên (thien24112005@gmail.com)

- 02 - System low priority notification (hệ thống thông báo ưu tiên thấp): Thông báo hệ thống hoặc thông báo trạng thái. Không có sự liên quan về bảo mật.
- 03 - Successful/Authorized events (sự kiện thành công/được ủy quyền): Bao gồm các lần đăng nhập thành công, tường lửa cho phép sự kiện, v.v.
- 04 - System low priority error(lỗi ưu tiên hệ thống thấp): Các lỗi liên quan đến cấu hình hoặc thiết bị/ứng dụng không sử dụng. Chúng không có sự liên quan về bảo mật và thường được gây ra bởi các cài đặt mặc định hoặc kiểm thử phần mềm.
- 05 - User generated error(lỗi do người dùng tạo): Chúng bao gồm mật khẩu bị bỏ lỡ, hành động bị từ chối, v.v. Chính chúng không có sự liên quan về bảo mật.
- 06 - Low relevance attack (tấn công mức độ liên quan thấp): Chúng chỉ ra một con sâu hoặc virus không ảnh hưởng đến hệ thống (như mã màu đỏ cho các máy chủ apache, vv). Chúng cũng bao gồm các sự kiện IDS thường xuyên và các lỗi thường xuyên.
- 07 - “Bad word” matching (kết hợp “Từ xấu”): Chúng bao gồm các từ như "bad", "error", v.v. Những sự kiện này hầu như không được phân loại và có thể có một số mức độ liên quan về bảo mật.
- 08 - First time seen (lần đầu tiên nhìn thấy): Bao gồm các sự kiện lần đầu tiên được xem. Lần đầu tiên một sự kiện IDS được kích hoạt hoặc lần đầu tiên người dùng đăng nhập. Nếu bạn mới bắt đầu sử dụng OSSEC HIDS, những thông báo này có thể sẽ thường xuyên. Sau một thời gian sẽ giảm dần, Nó cũng bao gồm các hành động bảo mật có liên quan (như bắt đầu của một sniffer).
- 09 - Error from invalid source(lỗi từ nguồn không hợp lệ): Bao gồm các lần đăng nhập dưới dạng người dùng không xác định hoặc từ nguồn không hợp lệ. Có thể có sự liên quan về bảo mật (đặc biệt nếu được lặp lại). Chúng cũng bao gồm các lỗi liên quan đến tài khoản "quản trị" (root).
- 10 - Multiple user generated errors (tập hợp lỗi do người dùng tạo): Chúng bao gồm nhiều mật khẩu không hợp lệ, nhiều lần đăng nhập không thành công, v.v. Họ có thể chỉ ra một cuộc tấn công hoặc có thể chỉ là người dùng vừa quên thông tin đăng nhập của mình.
- 11 - Integrity checking warning (cảnh báo kiểm tra tính toàn vẹn): Chúng bao gồm các thông báo liên quan đến việc sửa đổi các tệp nhị phân hoặc sự hiện diện của rootkit (bằng kiểm tra root). Nếu bạn chỉ cần sửa đổi cấu hình hệ thống của bạn, bạn sẽ được báo về các thông báo "syscheck". Nó có thể chỉ ra một cuộc

Downloaded by T? Thiên (thien24112005@gmail.com)

tấn công thành công. Cũng bao gồm các sự kiện IDS sẽ bị bỏ qua (số lần lặp lại cao).

- 12 - High importancy event (sự kiện quan trọng cao): Chúng bao gồm các thông báo lỗi hoặc cảnh báo từ hệ thống, hạt nhân, v.v. Chúng có thể chỉ ra một cuộc tấn công chống lại một ứng dụng cụ thể.
- 13 - Unusual error (high importance) - Lỗi bất thường (mức độ quan trọng cao): Hầu hết các lần khớp với một kiểu tấn công chung.
- 14 - High importance security event (sự kiện bảo mật quan trọng cao): Hầu hết thời gian được thực hiện với sự tương quan và nó chỉ ra một cuộc tấn công.
- 15 - Severe attack (tấn công nghiêm trọng): Cần chú ý ngay lập tức.

- Rules trong OSSEC được hỗ trợ quản lý theo nhóm, các bộ luật được xây dựng sẵn trong hệ thống OSSEC thuộc 12 nhóm sau:

  - invalid_login
  - authentication_success
  - authentication_failed
  - connection_attempt
  - attacks
  - adduser
  - sshd
  - ids
  - firewall
  - squid
  - apache
  - syslog

- Người quản trị hệ thống admin có thể tự tạo một group chứa một hoặc nhiều bộ luật mới.

2.4.1.2. Phân loại

- Trong OSSEC, luật được chia thành 2 loại: Luật nguyên tố và luật kết hợp:

  - Luật nguyên tố - các luật xử lý 1 sự kiện: cảnh báo, thông báo hay hành động ứng phó sẽ xuất hiện khi có 1 sự kiện thỏa mãn. Ví dụ: Bao nhiêu lần đăng nhập thất bại sẽ xuất hiện bấy nhiêu lần thông báo.

VD:

```
<rule id="500" level="0">
  <category>ossec</category>
  <decoded_as>ossec</decoded_as>
  <description>Grouping of ossec rules.</description>
</rule>
```

  - Luật kết hợp – xử lý nhiều sự kiện một lúc trong 1 luật:

Downloaded by T? Thiên (thien24112005@gmail.com)

- Có thể sử dụng với thẻ Frequency và Timeframe để xử lý một sự kiện được diễn ra nhiều lần.
- Các luật được kết hợp với nhau thông qua id, sử dụng thẻ <if_sid> hoặc (<if_matched_sid> hoặc <same_id> hoặc <same_source_ip>, các thẻ này được kết hợp với Frequency và Timeframe).

VD:

```
<rule id="501" level="3">
  <if_sid>500</if_sid>
  <if_fts />
  <options>alert_by_email</options>
  <pcre2>Agent started</pcre2>
  <description>New ossec agent connected.</description>
</rule>
```

2.4.2 Thêm luật vào OSSEC

- Các luật của OSSEC được lưu trong đường dẫn /var/ossec/rules. Ở đây sẽ có rất nhiều file .xml chứa các tập rule của OSSEC. Trong đó ta chỉ nên sửa đổi các tập rules ở file local_rules.xml vì đây là thư mục dành riêng cho các file người dùng tự thêm vào.

```
root@sa-VirtualBox:/var/ossec/rules# ls
apache_rules.xml            msauth_rules.xml            roundcube_rules.xml
apparmor_rules.xml          ms_dhcp_rules.xml           rules_config.xml
arpwatch_rules.xml          ms-exchange_rules.xml       sendmail_rules.xml
asterisk_rules.xml          ms_firewall_rules.xml       smbd_rules.xml
attack_rules.xml            ms_ftpd_rules.xml           solaris_bsm_rules.xml
cimserver_rules.xml         ms_ipsec_rules.xml          sonicwall_rules.xml
cisco-ios_rules.xml         ms_powershell_rules.xml     spamd_rules.xml
clam_av_rules.xml           ms-se_rules.xml             squid_rules.xml
courier_rules.xml           mysql_rules.xml             sshd_rules.xml
dnsmasq_rules.xml           named_rules.xml             symantec-av_rules.xml
dovecot_rules.xml           netscreenfw_rules.xml       symantec-ws_rules.xml
dropbear_rules.xml          nginx_rules.xml             syslog_rules.xml
exim_rules.xml              nsd_rules.xml               sysmon_rules.xml
firewalld_rules.xml         openbsd-dhcpd_rules.xml     systemd_rules.xml
firewall_rules.xml          openbsd_rules.xml           telnetd_rules.xml
ftpd_rules.xml              opensmtpd_rules.xml         topleveldomain_rules.xml
hordeimp_rules.xml          ossec_rules.xml             trend-osce_rules.xml
ids_rules.xml               owncloud_rules.xml          unbound_rules.xml
imapd_rules.xml             pam_rules.xml               vmpop3d_rules.xml
kesl_rules.xml              php_rules.xml               vmware_rules.xml
last_rootlogin_rules.xml    pix_rules.xml               vpn_concentrator_rules.xml
lighttpd_rules.xml          policy_rules.xml            vpopmail_rules.xml
linux_usbdetect_rules.xml   postfix_rules.xml           vsftpd_rules.xml
local_rules.xml             postgresql_rules.xml        web_appsec_rules.xml
mailscanner_rules.xml       proftpd_rules.xml           web_rules.xml
mcafee_av_rules.xml         proxmox-ve_rules.xml        wordpress_rules.xml
mhn_cowrie_rules.xml        psad_rules.xml              zeus_rules.xml
mhn_dionaea_rules.xml       pure-ftpd_rules.xml
ms1016_usbdetect_rules.xml  racoon_rules.xml
```

- Để truy cập vào file **local_rules**, chúng ta sử dụng câu lệnh **sudo nano /var/ossec/rules/local_rules.xml**. Sau đó, chúng ta có màn hình sau:

Downloaded by T? Thiên (thien24112005@gmail.com)

```
sa@sa-VirtualBox: ~
  GNU nano 2.5.3        File: /var/ossec/rules/local_rules.xml

<!-- @(#) $Id: ./etc/rules/local_rules.xml, 2011/09/08 dcid Exp $

  -  Example of local rules for OSSEC.
  -
  -  Copyright (C) 2009 Trend Micro Inc.
  -  All rights reserved.
  -
  -  This program is a free software; you can redistribute it
  -  and/or modify it under the terms of the GNU General Public
  -  License (version 2) as published by the FSF - Free Software
  -  Foundation.
  -
  -  License details: http://www.ossec.net/en/licensing.html
  -->


<!-- Modify it at your will. -->

<group name="local,syslog,">
                                  [ Read 57 lines ]
^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Justify   ^C Cur Pos
^X Exit      ^R Read File ^\ Replace   ^U Uncut Text^T To Spell  ^_ Go To Line
```

- Chúng ta thêm luật bằng thẻ **<rule>** như rule mẫu có ID 100001 dưới đây.

```
sa@sa-VirtualBox: ~
  GNU nano 2.5.3        File: /var/ossec/rules/local_rules.xml

  <!-- Note that rule id 5711 is defined at the ssh_rules file
    -  as a ssh failed login. This is just an example
    -  since ip 192.0.2.1 shouldn't be used anywhere.
    -  Level 0 means ignore.
    -->
  <rule id="100001" level="0">
    <if_sid>5711</if_sid>
    <srcip>192.0.2.1</srcip>
    <description>Example of rule that will ignore sshd </description>
    <description>failed logins from IP 1.1.1.1.</description>
  </rule>


  <!-- This example will ignore ssh failed logins for the user name XYZABC.
    -->
  <!--
  <rule id="100020" level="0">
    <if_sid>5711</if_sid>
    <user_pcre2>XYZABC</user_pcre2>

^G Get Help  ^O Write Out ^W Where Is  ^K Cut Text  ^J Justify   ^C Cur Pos
^X Exit      ^R Read File ^\ Replace   ^U Uncut Text^T To Spell  ^_ Go To Line
```

2.5 Xây dựng 3 kịch bản phát hiện tấn công

- Chuẩn bị:
  - Một máy Ubuntu sẽ đóng vai trò máy server kiêm máy tấn công. Cấu hình địa chỉ 1 IP tĩnh cho máy (VD: 192.168.1.101)

Downloaded by T? Thiên (thien24112005@gmail.com)

- Một máy Ubuntu sẽ đóng vai trò máy nạn nhân và OSSEC agent được cài ở máy này. Cấu hình 1 địa chỉ IP tĩnh cho máy (VD: 192.168.1.103)

Những cài đặt khác cho 2 máy:

- Máy server:
  - Cài đặt xHydra (phần mềm tấn công brute force):
    sudo apt install hydra && sudo apt install hydra-gtk
  - Cài đặt sqlmap (phần mềm tấn công sql injection):
    sudo apt install sqlmap
- Máy agent:
  - Tắt tường lửa (nếu chưa tắt):
    sudo ufw disable
  - Mở port 22 (nếu chưa mở):
    sudo apt-get install openssh-server
    sudo systemctl start sshd.service
  - Cài đặt Apache web server (tạo web để tấn công sql injection):
    sudo apt install apache2
  - Mở file /var/ossec/etc/ossec.conf và thêm đoạn lệnh phía dưới (cho phép OSSEC theo dõi log của web server):
    <localfile>
    <log_format>apache</log_format>
    <location>/var/log/apache2/access.log</location>
    </localfile>

2.5.1 SSH Brute force

- Luật sử dụng:

```
root@sa-VirtualBox: /var/ossec/rules
GNU nano 2.5.3            File: sshd_rules.xml

<rule id="5712" level="10" frequency="6" timeframe="120" ignore="60">
  <if_matched_sid>5710</if_matched_sid>
  <description>SSHD brute force trying to get access to </description>
  <description>the system.</description>
  <same_source_ip />
  <group>authentication_failures,</group>
</rule>
```

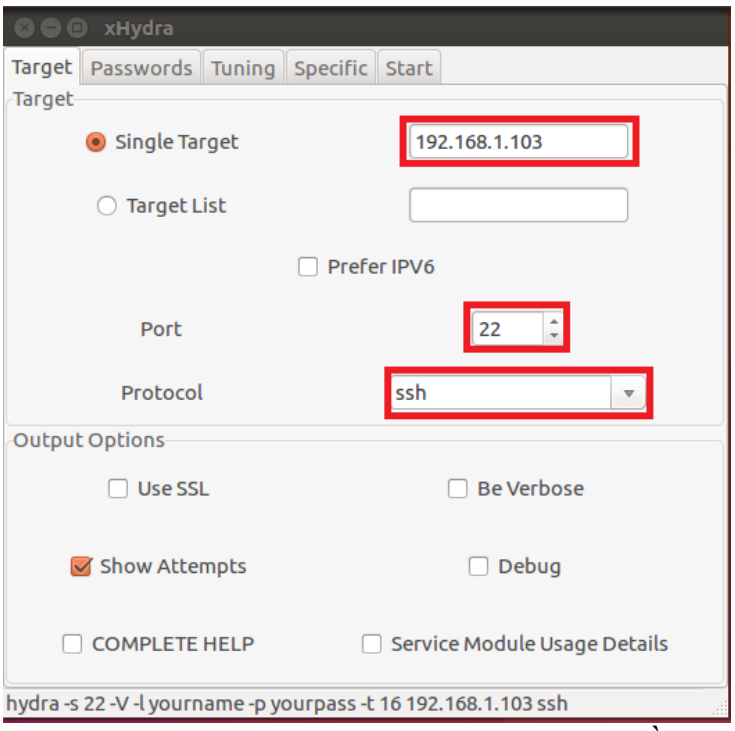
- Phân tích luật:
  - level="10": luật nằm ở mức độ cảnh báo 10
  - frequency = "6" và timeframe = "120": nếu luật 5170 so sánh khớp 6 lần trong vòng 120 giây thì luật này mới kích hoạt thông báo
  - ignore = "60": luật này sẽ không kích hoạt thông báo mới trong vòng 60 giây sau khi nó được kích hoạt

Downloaded by T? Thiên (thien24112005@gmail.com)

- <if_matched_sid>5710</if_matched_sid>: luật này được kiểm tra sau khi luật 5170 được kích hoạt 1 số lần nhất định. Luật 5170 được kích hoạt khi xuất hiện log của hệ thống có các cụm từ illegal user|invalid user (tức là máy đang bị tấn công SSH)
- <description>SSHD brute force trying to get access to the system.</description>: mô tả luật
- <same_source_ip />: các log kích hoạt luật 5170 ghi nhận cùng 1 địa chỉ IP tấn công
- <group>authentication_failures,</group>: luật này nằm trong nhóm luật lỗi đăng nhập

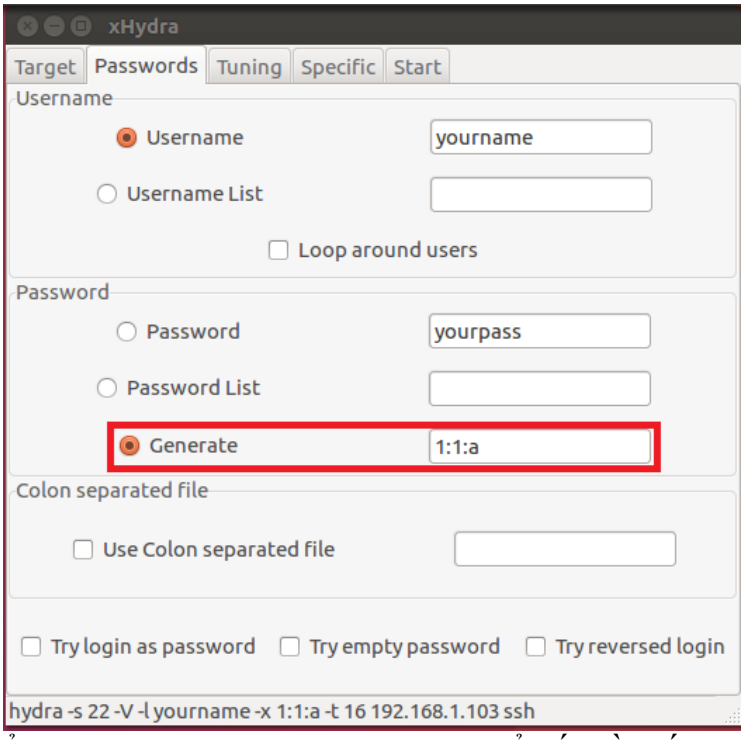
- Mô tả cách demo:

- Bước 1: Bật xHydra ở máy tấn công. Ở trang Target, chúng ta nhập địa chỉ IP máy nạn nhân, chỉnh port về 22 và protocol về ssh

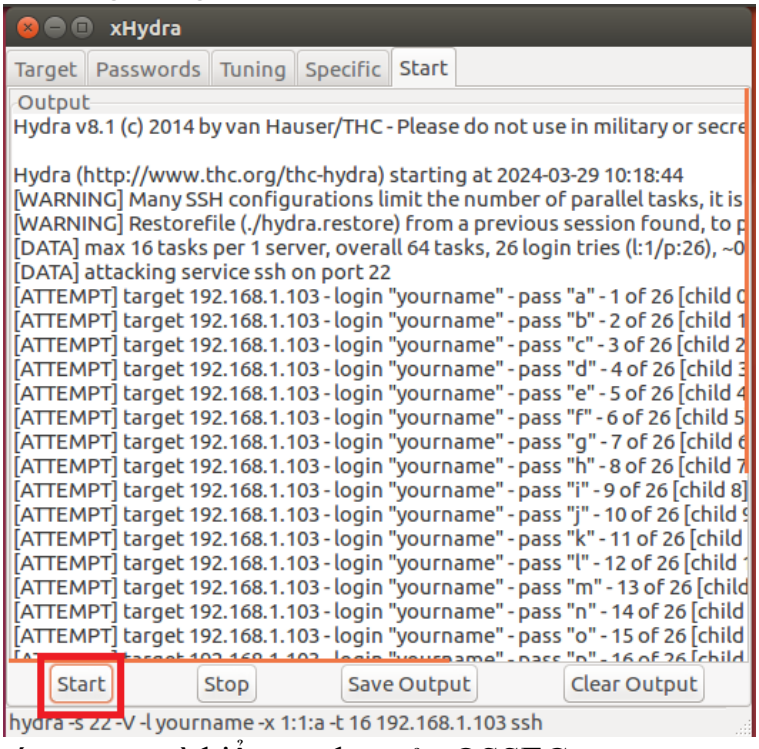


- Bước 2: Ở trang Password, chúng ta chỉnh password về generate

Downloaded by T? Thiên (thien24112005@gmail.com)

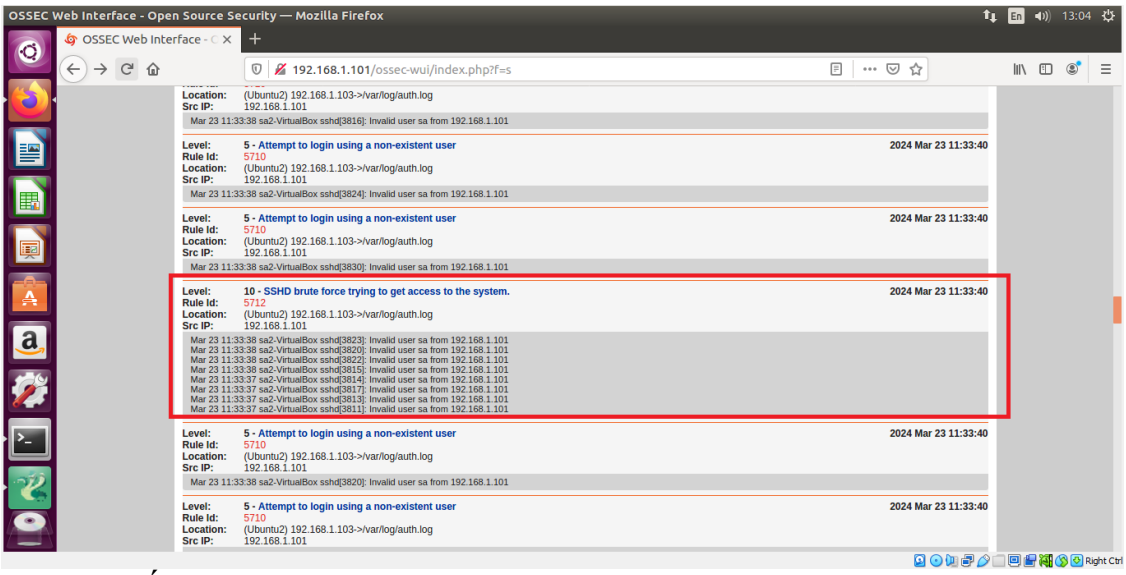


- Bước 3: Chuyển sang trang Start và chọn start để bắt đầu tấn công



- Bước 4: Về máy server và kiểm tra log của OSSEC

Downloaded by T? Thiên (thien24112005@gmail.com)



- Kịch bản tấn công:
  - c

2.5.2 SQL Injection

- Luật sử dụng:

```
<rule id="31103" level="6">
  <if_sid>31100,31108</if_sid>
  <url_pcre2>=select%20|select\+|insert%20|%20from%20|%20where%20|union%20|</$
  <url_pcre2>union\+|where\+|null,null|xp_cmdshell</url_pcre2>
  <description>SQL injection attempt.</description>
  <group>attack,sql_injection,</group>
</rule>
```

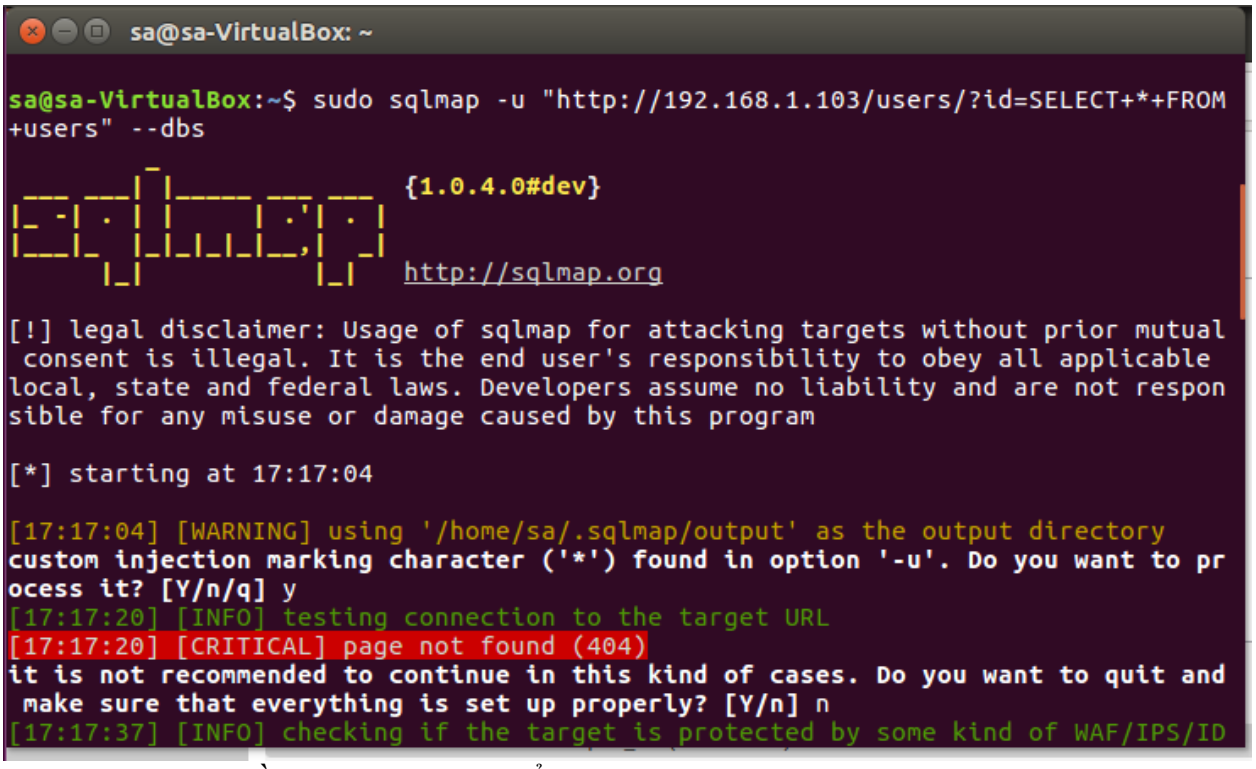
- Phân tích luật:
  - level = “6”: luật có mức độ cảnh báo là 6
  - <if_sid>31100,31108</if_sid>: 2 luật 31100 và 31108 cần phải được kích hoạt trước khi kiểm tra luật này. Luật 31100 kiểm tra các log liên quan đến web và luật 31108 kiểm tra nội dung thanh URL
  - <url_pcre2>=select%20|select\+|insert%20|%20from%20|%20where%20|union%20|union\+|where\+|null,null|xp_cmdshell</url_pcre2>: kiểm tra nếu thanh địa chỉ xuất hiện các từ select, insert, from, … các từ nằm trong cú pháp của 1 câu truy vấn SQL
  - <description>SQL injection attempt.</description>: mô tả luật
  - <group>attack,sql_injection,</group>: luật này thuộc nhóm luật tấn công và sql_injection

- Mô tả cách demo:

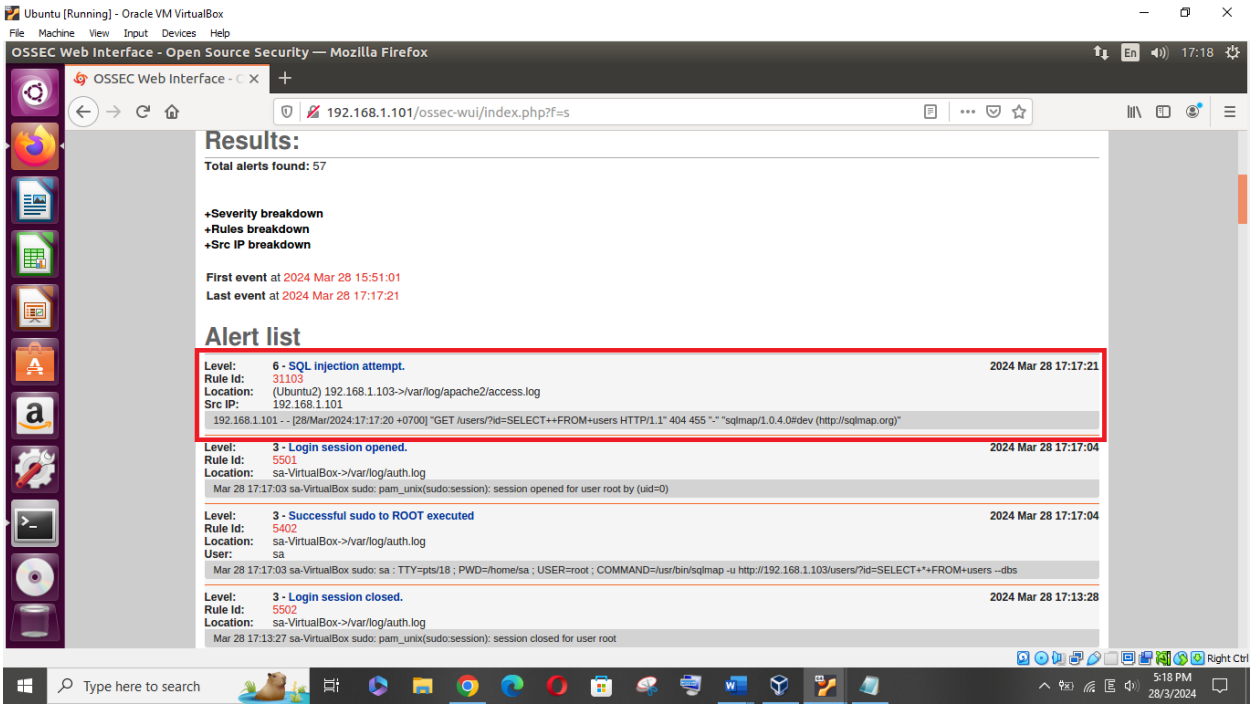
- Bước 1: Sử dụng sqlmap trên máy tấn công để thực hiện tấn công. Vào Terminal của máy tấn công và nhập lệnh:

Downloaded by T? Thiên (thien24112005@gmail.com)

sudo sqlmap -u "http:// <IP máy nạn nhân> /users/?id=SELECT+*+FROM+users" –dbs



- Bước 2: Về máy server và kiểm tra log của OSSEC



Downloaded by T? Thiên (thien24112005@gmail.com)

- Kịch bản tấn công: Một kẻ tấn công thực hiện một cuộc tấn công SQL Injection bằng cách chèn các câu truy vấn độc hại vào thanh địa chỉ (URL) của trình duyệt. Trong câu truy vấn, kẻ tấn công có thể sử dụng các từ khóa phổ biến như select, insert, from, where, union, null, xp_cmdshell, để thực hiện các thao tác độc hại như truy vấn thông tin nhạy cảm từ cơ sở dữ liệu hoặc thực thi mã nguy hiểm.
- Cách hoạt động của đoạn mã:

• Đoạn mã luật OSSEC được thiết lập để kiểm tra mỗi yêu cầu gửi đến server có chứa các từ khóa phổ biến trong cuộc tấn công SQL Injection.

• Khi một yêu cầu chứa các từ khóa như select, insert, from, where, union, null, xp_cmdshell được gửi đến server, luật sẽ kích hoạt.

• Hệ thống OSSEC sẽ phát hiện yêu cầu này là một cuộc tấn công SQL Injection và ghi nhận lại sự việc, cảnh báo cho quản trị viên thông qua các cơ chế cảnh báo hoặc ghi lại vào các bản ghi kiểm tra.

• Quản trị viên có thể kiểm tra các bản ghi kiểm tra để phát hiện và xử lý sự cố tấn công SQL Injection.

2.5.3 Rootkit

- Luật sử dụng:

```
<rule id="510" level="7">
  <if_sid>509</if_sid>
  <description>Host-based anomaly detection event (rootcheck).</description>
  <group>rootcheck,</group>
  <if_fts />
</rule>
```

- Phân tích luật:
  - level = “7”: luật nằm ở mức độ cảnh báo 7
  - <if_sid>509</if_sid>: luật được kiểm tra nếu luật 509 được kích hoạt. Luật 509 báo hiệu đang xảy ra rootcheck (tức là luật này chỉ được kiểm tra khi rootcheck đang hoạt động)
  - <description>Host-based anomaly detection event (rootcheck).</description>: mô tả luật
  - <group>rootcheck,</group>: luật nằm ở nhóm rootcheck
  - <if_fts />: tag này kết nối luật với 1 bộ decoder giúp phát hiện file mới xuất hiện trong root

- Cách thực hiện demo:
  - Bước 1: Ở máy nạn nhân ta truy cập thư mục shv5:

cd shv5/

  - Bước 2: Ta sẽ thấy 1 file là setup ở thư mục này. Cấp toàn bộ quyền cho thư mục này bằng lệnh:

Downloaded by T? Thiên (thien24112005@gmail.com)

chmod 777 setup

- Bước 3: Chạy file setup ở trên:

./setup

- Kịch bản tấn công: Một kẻ tấn công xâm nhập vào hệ thống máy chủ và cố gắng thêm một tập tin mới vào thư mục root của hệ thống để tiến hành các hoạt động không đúng đắn, như triển khai phần mềm độc hại hoặc thu thập thông tin trái phép.
- Cách hoạt động của đoạn mã để phát hiện đợt tấn công:
  - Khi kẻ tấn công thêm một tập tin mới vào thư mục root của hệ thống, hành động này sẽ tạo ra một sự kiện file mới xuất hiện.
  - Đoạn mã luật OSSEC đã được cấu hình để theo dõi sự xuất hiện của các tập tin mới trong root sẽ được kích hoạt.
  - Luật với ID là 510 sẽ được kích hoạt và kiểm tra bởi hệ thống OSSEC.
  - OSSEC sẽ phát hiện sự xuất hiện của tập tin mới trong root và ghi nhận sự kiện như một sự việc không bình thường.
  - Hệ thống quản trị sẽ nhận được cảnh báo về hành động này, giúp người quản trị phản ứng kịp thời và xử lý tình huống tấn công.

3. Kết luận

Trong bài tiểu luận này, chúng ta đã đi sâu vào việc tìm hiểu về kiến trúc, cài đặt và cấu hình của OSSEC, một hệ thống giám sát an ninh mạng mạnh mẽ và linh hoạt. OSSEC cung cấp một cơ chế mạnh mẽ để giám sát hệ thống và phát hiện các mối đe dọa an ninh mạng. Chúng ta đã thảo luận về cách OSSEC hoạt động, bao gồm việc thu thập dữ liệu từ các nguồn khác nhau như logs hệ thống, dịch vụ mạng và các tập tin quan trọng. Chúng ta cũng đã xem xét về việc cấu hình OSSEC để phù hợp với môi trường cụ thể của từng tổ chức.

Tiếp theo, chúng ta đã nắm vững về cấu trúc và ngôn ngữ của các luật trong OSSEC. Các luật này định nghĩa các quy tắc và mẫu để phát hiện các hoạt động bất thường hoặc có hại trên hệ thống. Chúng ta đã thảo luận về cách sử dụng các luật có sẵn, tùy chỉnh chúng và thêm mới để phù hợp với nhu cầu cụ thể của tổ chức.

Cuối cùng, chúng ta đã đưa ra ba ví dụ về các kịch bản tấn công mà OSSEC có thể phát hiện và cảnh báo. Ba ví dụ này bao gồm tấn công SQL Injection, tấn công truy cập không hợp lệ vào WordPress, và tấn công quét mạng. Chúng ta đã thảo luận về cách các luật trong OSSEC có thể được kích hoạt để phát hiện các hành vi này và cung cấp cảnh báo cho những người quản trị hệ thống.

Tổng quan, OSSEC là một công cụ mạnh mẽ trong hệ thống an ninh mạng, cung cấp khả năng giám sát và phát hiện các mối đe dọa một cách hiệu quả. Qua bài tiểu luận này, chúng ta hi vọng rằng độc giả sẽ có cái nhìn tổng quan và sâu sắc về OSSEC và cách nó có thể được triển khai để bảo vệ hệ thống mạng.

Downloaded by T? Thiên (thien24112005@gmail.com)